

Cyber Defenders – Tusk Infostealer Lab

Analyze threat intelligence and malware configuration to identify TTPs, extrace IOCs, and track cryptocurrency flow of the Tusk Infostealer campaign.

MD5: E5B8B2CF5B244500B22B665C87C11767

Category: Threat Intel

Tools: Virus Total, Securelist by Kaspersky

Scenario:

A blockchain development company detected unusual activity when an employee was redirected to an unfamiliar website while accessing a DAO management platform. Soon after, multiple cryptocurrency wallets linked to the organization were drained.

Investigators suspect a malicious tool was used to steal credentials and exfiltrate funds.

Your task is to analyze the provided intelligence to uncover the attack methods, identify indicators of compromise, and track the threat actor's infrastructure.

What I knew at the begining:

523d4eb71af86090d2d8a6766315a027fdec842041d668971bfbbbd1fe826722

Dohledala jsem ho ve Virus Total

1) In **KB**, what is the size of the malicious file?

I searched the MD5 hash on VirusTotal to gather additional Information. In the „Details“ section on VirusTotal, I found the file size of the malicious sample.

Answer: 921.36 KB

The screenshot displays the VirusTotal interface for a specific file. The top navigation bar includes tabs for DETECTION, DETAILS, RELATIONS, BEHAVIOR, and COMMUNITY. The 'DETAILS' tab is active. Below the navigation bar, there is a section for 'Join our Community' and a link to 'automate checks'. The main content area is titled 'Basic properties' and lists various file attributes:

- MD5: e5b8b2cf5b244500b22b665c87c11767
- SHA-1: b0b3f5227871c6480cab8102c480a527fec8
- SHA-256: 523d4eb71af86090d2d8a6766315a027fdec842041d668971bfbbbd1fe826722
- Vhash: 1950a666d5c0d5d155103040300250032121a103533208b59
- Authenticatash: f88f239bb9277a1106184f90db2eae77d5cfa92cf75c72fa4468d5fb7f5ac
- Imphash: 1a157842e5cd99d6e1fd082c5f25c9fa
- SSDEEP: 24576:VUUhWq3/guWU4Vgy0eUndaE0Jqyf1T9A-vUR4qvUJ4VgceXE0oxfC
- TLSH: T13E155B225F58C037D5252A7ACC26DBE0243D7A201E205A4B3DEDBB4CDF77A316E152CB
- File type: Win32 DLL (executable) (windows) (win32) (pe) (peexe)
- Magic: PE32 executable (DLL) (GUI) Intel 80386, for MS Windows
- TrID: Win32 EXE PECompact compressed (generic) (63.7%) | Win32 Dynamic Link Library (generic) (10%) | Win64 Executable (generic) (10%) | Win32 Executable (generic) (6.9%) | OS/2 Executable (generic) (3.1%)
- DetectItEasy: PE32 | Compiler: Embarcadero Delphi (XE8) | Linker: Turbo Linker (2.25", Delphi) | DLL32, signed | Sign tool: Windows Authenticode (2.0) | PKCS #7
- Magika: PEBIN
- File size: 921.36 KB (943472 bytes)

Below the 'Basic properties' section, there is a 'History' section showing the file's submission and analysis history:

- Creation Time: 2018-08-29 07:53:20 UTC
- Signature Date: 2018-08-29 07:53:00 UTC
- First Submission: 2025-02-03 15:44:15 UTC
- Last Submission: 2025-08-20 15:43:27 UTC
- Last Analysis: 2026-06-17 09:31:41 UTC

- 2) **What word** do the threat actors use in log messages to describe their victims, based on the name of an ancient hunted creature?

In the „Community“ section on VirusTotal, I found a link to Securelist that discusses the Tusk Infostealer campaign.

mammoth

[Tusk: unraveling a complex infostealer campaign | InfoStealers](#)

We identified three active sub-campaigns (at the time of analysis) and 16 inactive sub-campaigns related to this activity. We dubbed it “Tusk”, as the threat actor uses the word “Mammoth” in log messages of initial downloaders – at least in the three active sub-campaigns we analyzed. “Mammoth” is slang used by Russian-speaking threat actors to refer to victims. Mammoths used to be hunted by ancient people and their tusks were harvested and sold.

- 3) The threat actor set up a malicious website to mimic a platform designed for creating and managing decentralized autonomous organizations (DAOs) on the MultiversX blockchain (peerme.io). What is the name of the malicious website the attacker created to simulate this platform?

Tidyme.io

[Tusk: unraveling a complex infostealer campaign | InfoStealers](#)

First sub-campaign (TidyMe)

In this campaign the actor simulated **peerme.io**, a platform for the creation and management of **decentralized autonomous organizations (DAOs)** on the MultiversX blockchain. It aims to empower crypto communities and projects by providing tools for governance, funding, and collaboration within a decentralized framework. The malicious website is **tidyme[.]io**.

- 4) Which cloud storage service did the campaign operators use to host malware samples for both macOS and Windows OS versions?

Dropbox

This campaign has several malware samples for macOS and Windows, both hosted on [Dropbox](#). In this post we will explore Windows samples only.

- 5) The malicious executable contains a configuration file that includes base64-encoded URLs and a password used for archived data decompression, enabling the download of second-stage payloads. What is the password for decompression found in this configuration file?

<https://securelist.com/tusk-infostealers-campaign/113367/>

Password is: newfile2024

Downloader routine

The **tidyme.exe** sample contains a configuration file called **config.json** which contains **base64**-encoded URLs and a password for archived data decompression, which is used to download the second-stage payloads. Here is the content of the file:

```
1 {  
2   "archive": "aHR0cHM6Ly93d3cuZHJvcGJveC5jb20vc2NsL2ZpL2N3NmpzYnA5ODF4eTg4dHprM29ibS9lcGRhdG"  
3   "password": "newfile2024",  
4   "bytes": "aHR0cDovL3RlcjRsb2FkLnB5dGhvbmFueXdoZXJlLnVvbS9nZXRicXRlcycm"  
5 }
```

The table below lists the decoded URLs:

- 6) What is the name of the function responsible for retrieving the field archive from the configuration file?

<https://securelist.com/tusk-infostealers-campaign/113367/>

downloadAndExtractArchive

The main downloader functionality is stored in `preload.js` file in two functions,

`downloadAndExtractArchive` and `loadFile`. The function `downloadAndExtractArchive` retrieves the field `archive` from the configuration file, which is an encoded Dropbox link, decodes it and stores the file from Dropbox to the path `%TEMP%/archive-<RANDOM_STRING>`. The downloaded file is a password-protected RAR file which will be extracted with the value of the field `password` in the configuration file, then all `.exe` files from this archive are executed.

- 7) In the third sub-campaign carried out by the operators, the attacker mimicked an AI translator project. What is the name of the legitimate translator, and what is the name of the malicious translator created by the attackers?

<https://securelist.com/tusk-infostealers-campaign/113367/>

yous.ai,voico.io

Third sub-campaign (Voico)

In this campaign, the threat actor was simulating an AI translator project named **YOUS**. The original website is **yous.ai**, while the malicious website is **voico[.]io**:

- 8) The downloader is tasked with delivering additional malware samples to the victim's machine, primarily infostealers like StealC and Danabot. What are the IP addresses of the **StealC C2 servers** used in the campaign?

<https://securelist.com/tusk-infostealers-campaign/113367/>

46.8.238.240 ,23.94.225.177

Za první IP se musí vložit mezera a pak čárka, aby to fungovalo

Network IoCs

Domain or IP	Details
46.8.238.240	StealC C2 Server
77.91.77.200	Download madHcCtrl files
23.94.225.177	StealC C2 Server

- 9) What is the address of the Ethereum cryptocurrency wallet used in this campaign?

<https://securelist.com/tusk-infostealers-campaign/113367/>

0xaf0362e215Ff4e004F30e785e822F7E20b99723A

Cryptocurrency wallet addresses

Crypto	Wallet Address
BTC	1DSWHiAW1iSFYVb86WQQUPn57iQ6W1DjGo
BTC	bc1qqkvqgqtpwq6g59xgwr2sccvmudejfxwyl8g9xg0
ETH	0xaf0362e215Ff4e004F30e785e822F7E20b99723A

What I learnt:

I learnt how to work with threat intelligence whilst analysing the Tusk Infostealer campaign. I practised searching for malware hashes on VirusTotal, reading sample details and using community comments to track down other relevant sources, such as an article on Securelist by Kaspersky. This helped me understand how a single indicator can be used to gradually build up a broader picture of the attack.

At the same time, I learnt to extract and interpret indicators of compromise, such as malicious domains, C2 server IP addresses, cryptocurrency wallets and malware configuration data. I now have a better understanding of how attackers mimic legitimate services, host payloads via cloud services and use downloaders to download other infostealers, such as StealC or Danabot.

Overall, the lab showed me how to correlate information from various sources, track attack infrastructure and map attackers' behaviour to specific techniques and procedures. I gained a more practical insight into the analysis of infostealer campaigns and how individual technical traces come together to form the full picture of an incident.